IS Audit & Control

Abdul-Rahman Mahmood
Assistant Professor, Computer Science, FAST-NU

abdulrahman@nu.edu.pk
alphapeeler.sf.net/pubkeys/pkey.htm
pk.linkedin.com/in/armahmood
bqb-tsid-asp
alphapeeler
alphapeeler
armahmood786
http://alphapeeler.sf.net/
reddit.com/user/alphapeeler
www.flickr.com/alphapeeler
http://alphapeeler.tumblr.com
armahmood786@jabber.org
alphapeeler@aim.com
abdulmahmood-sss
alphapeeler@icloud.com
pinterest.com/alphapeeler

Auditing Unix and Linux Operating Systems

Objectives

- • The history of Unix and Linux
- • Basic commands for getting around in the *nix environment
- • How to audit Unix and Linux systems, focusing on the following main areas:
- • Account management and password controls
- • File security and controls
- • Network security and controls
- • Audit logs
- • Security monitoring and general controls
- • Tools and resources for enhancing your *nix audits

Key Concepts

- Everything in Unix is a file. For example, if you type in a command and press ENTER, you are actually executing a file within the system that has the same name as the command you entered. And if you attach a device, such as a printer or storage, to your Unix system, it will be represented on the system as a file.
- There is only one file system within any given Unix system, and the root of that file system is the directory called /. Every directory and every file branches off this root directory. Since everything in Unix is a file, if you do a recursive listing off of the / directory, you will see every component of the system.

Key Concepts

- The system administrator (or superuser) account in Unix is called “root.” This account has full control over the system.
- If you can alter a file that someone is executing, you can easily capture his or her account.

File System Layout and Navigation

Directory	Description
/bin	Location of most of the system binaries (programs)
/sbin	Contains binaries that are reserved for use by privileged accounts
/etc	Contains system configuration files
/boot	Contains location of the kernel in many systems
/home	Typical location for user home directories
/var	Contains information that programs need to track as they run (such as the process ID on the system); usually contains log files as well
/lib	System and application libraries that aren't executed directly but are used by applications as they run
/opt	Includes many installed add-on packages
/usr	Another place for user-added packages; often duplicates many of the top-level directories within itself, so you'll have /usr/etc, /usr/bin, and so on; documentation is often placed into /usr/share
/root	Often contains the home directory for the root account
/tmp	Temporary directory that any user typically can access; often cleared when the system is booted
/mnt	Remote file systems may be mounted here
/dev	Represents the concept that everything is a file, so you will find device files here representing the hardware in your system
/proc	This pseudo-file system doesn't exist on a physical disk, but contains memory-resident information about both the processes running on a system and the system itself

Common Unix and Linux Directories

Common Linux / Unix Navigation Commands

Command	Meaning	Description	Tips for Use
`cd`	Change directory	Changes directory location as you would from the Windows command prompt	`cd ~` changes directory to user's home directory `.` signifies current directory `..` signifies parent directory
`ls`	List directory contents	Lists the contents of a directory along with information such as ownership, permissions, file size, and so on, when used with the `-l` option	`ls -l` uses long listing format for the files within the directory `ls -ld` provides the long listing format for the directory itself `ls -al` provides the long listing format for all directory contents, including hidden files `ls -alR` provides a recursive directory listing, using the long listing format and displaying hidden files `ls -altr` provides the long listing format, displaying the directory's contents in reverse chronological order
`pwd`	Print working directory	Displays the current working directory on the screen	Auditors can use this command when copying screen output for an audit to show on workpapers where they are working on the system

`more`
`cat`
`less`
	Lists file contents	Lists the contents of a file	`cat` displays all the file's contents at once
			`more` displays the file's contents one page at a time
			`less` displays the file's contents one page at a time and allows backward navigation

`ypcat`	List NIS file contents	Lists the contents of a centralized NIS file	Displays the contents of the NIS password and group files if you're using NIS for centralized account management
`su`	Switch user	Allows a user to switch to another user ID	Works only if you have "root" access or if you know the password of the account to which you want to switch

Common Linux and Unix Navigation Commands

File System Permissions

Permissions on a file or directory:

	Owner			Group			World		
Available permissions	Read	Write	Execute	Read	Write	Execute	Read	Write	Execute
Assigned permissions	r	w	x	r		x	r		
Binary (1 = Yes, 0 = No)	1	1	1	1		1	1		
Decimal value	4	2	1	4		1	4		
Cumulative result	7			5			4		

Resulting permissions: 754 (or) `rwxr-xr--`

Unix permissions

Interaction between file and directory permissions

File Permissions	Directory Permissions: -	r	x	wx
-	No access	No access	No access	Delete file
r	No access	No access	Read data	Delete file or read data
w	No access	No access	Add to or clear data	Delete file or add to or clear data
rw	No access	No access	Update data	Delete file or update data
x	Can't execute	Can't execute	Execute	Delete file or execute

Unix Password File

- The /etc/passwd file (Table 7-3) contains account information for all users. Each account on the local system will have a single line in the /etc/passwd file. The system refers to this file when a user attempts to authenticate. Lines in /etc/password have this format:
- account:password:UID:GID:GECOS:directory:shell
- https://www.cyberciti.biz/faq/understanding-etcpasswd-file-format/

Users and Authentication

- /etc/passwd, /etc/shadow, and /etc/group.

Field	Use
account	Represents the user to the system. This name is used when the user logs in.
password	Encrypted password. It may be kept in /etc/shadow instead; if so, this field simply will contain an `*`, `x`, `!`, or other character.
UID	Numeric user ID.
GID	Numeric group ID for the user's primary group.
GECOS	Optional field used to store arbitrary additional information about the account. A typical use would be the real name and/or employee ID of the user.
directory	Location of the user's home directory.
shell	User's default shell, the command-line environment that interprets commands and passes them to the kernel.

Components of a Unix Password File